BOUMDJEL CYRILLE

MAT : CM-UGA-24FS0788

FILIERE : SISD

UE : SIS589

# TP : CHAP1

**Ex. 1.1 — Diagnostic de maturité.** Appliquez la grille (tab. 1.3) à LiZbiZ-SIS.

**Niveau 1**

**Justification** : L'entreprise possède l'infrastructure. Cependant, la détection semble encore basée sur des alertes génériques sans règles métier spécifiques, plaçant l'entité au-dessus du niveau initial 1. Le SOC n'a aucune visibilité structurée. Sans SIEM ni collecte centralisée des logs, la détection dépend entièrement des signalements utilisateurs. Le MTTD > 7 jours signifie qu'une attaque peut persister plus d'une semaine sans être détectée, exposant l'organisation à des dommages critiques (exfiltration, ransomware, pivoting).

**Correctives prioritaires :**

- Déployer un SIEM de base (ex. Elastic SIEM, Microsoft Sentinel) avec collecte des logs AD, firewall et endpoints
- Définir un processus minimal de gestion des incidents avec des niveaux de sévérité et une astreinte d'escalade

**Niveau 2**

**Justification :** Le SIEM est en place mais les règles par défaut génèrent un volume d'alertes non triées, provoquant de la fatigue d'alerte. Les analystes passent leur temps à trier manuellement, ce qui maintient le MTTD entre 2 et 7 jours et masque les incidents réels dans le bruit.

**Correctives prioritaires :**

- Implémenter un système de ticketing et de triage (ex. TheHive) avec priorisation automatique par criticité actif/vulnérabilité
- Affiner et contextualiser les règles de détection en désactivant les règles à fort taux de faux positifs et en les adaptant au contexte métier

**Niveau 3**

**Justification** : Les règles sont personnalisées et le triage est opérationnel (FPR < 50 %), mais la détection reste réactive. Le SOC répond aux alertes sans anticiper les menaces. Le MTTD < 24 h est acceptable mais insuffisant face aux attaques modernes dont le temps de déplacement latéral peut être inférieur à quelques heures.

**Correctives prioritaires :**

- Intégrer une source de Cyber Threat Intelligence (CTI) pour enrichir les alertes avec des IOCs et TTPs connus (MITRE ATT&CK)
- Mettre en place des métriques SOC formelles (MTTD, MTTR, taux de faux positifs) pour piloter l'amélioration continue

**Niveau 4**

**Justification :** Le threat hunting proactif et la CTI intégrée permettent d'atteindre un FPR < 30 % et un MTTD < 4 h. Cependant, les processus de réponse restent majoritairement manuels, ce qui crée un goulot d'étranglement humain à grande échelle et limite la capacité à traiter des volumes d'incidents élevés.

Actions correctives prioritaires :

- Déployer une plateforme SOAR (ex. Splunk SOAR, Palo Alto XSOAR) pour automatiser les playbooks de réponse sur les incidents récurrents
- Structurer un programme de threat hunting récurrent avec des hypothèses documentées basées sur les campagnes actives (OSINT, ISACs sectoriels)

**Niveau 5**

**Justification :** C'est le niveau d'excellence opérationnelle. Le SOAR, le ML et l'automatisation permettent une détection prédictive avec un MTTD < 1 h. Le risque à ce stade est la dépendance technologique et la dérive des modèles ML sur de nouvelles menaces, ainsi que la difficulté à maintenir les compétences humaines face à l'automatisation croissante.

**Actions correctives prioritaires :**

- Mettre en place un programme de red team/purple team continu pour valider en permanence l'efficacité des détections et éviter l'effet « fausse sécurité »
- Gouverner et auditer les modèles ML (drift détection, biais, réentraînement régulier) pour garantir leur pertinence face à l'évolution des TTPs adversaires

## Ex. 1.2 — Sélection de sources.

| Priorité | Sources | Menaces détectables |
|---|---|---|
| **1** | **Serveur Windows AD** | ▪ Brute force / credential stuffing (Event ID 4625, échec d'authentification)<br>▪ Escalade de privilèges (Event ID 4672, 4728, ajout aux groupes privilégiés)<br>▪ Création de comptes suspects<br>▪ Pass-the-Hash / Pass-the-Ticket<br>▪ Mouvement latéral (Event ID 4624, connexion depuis un poste inhabituel) |

| | | |
|---|---|---|
| **2** | **Firewall pfSense** | ▪ Brute force / credential stuffing (Event ID 4625, échec d'authentification)<br>▪ Escalade de privilèges (Event ID 4672, 4728, ajout aux groupes privilégiés)<br>▪ Création de comptes suspects<br>▪ Pass-the-Hash / Pass-the-Ticket<br>▪ Mouvement latéral (Event ID 4624, connexion depuis un poste inhabituel) |
| **3** | **Proxy Squid** | ▪ Scans de ports et reconnaissance réseau<br>▪ Connexions vers des serveurs C2 (Command & Control)<br>▪ Exfiltration de données vers l'extérieur<br>▪ Tentatives d'accès non autorisées depuis Internet |
| **4** | **Serveur ERP (windows)** | ▪ **Acces non autorisé au données de l'entreprise**<br>▪ **modification de la DATABASE** |
| **5** | **Serveur Linux Apache** | ▪ **Injection SQL**<br>▪ **scan de vulnérabilité web**<br>▪ Dépôt de web shell (accès anormal à des fichiers .php/.py suspects)<br>▪ Scanning applicatif automatisé (volume de requêtes anormal)<br>▪ Exploitation de CVE connues sur Apache |

## Ex. 1.3 — Règle de corrélation

```
<!-- Règle de base : connexion SMB réussie (Event 4624 LogonType 3) -->
<rule id="100200" level="5">
<if_sid>60103</if_sid><!-- Windows logon success -->
<field name="win.eventdata.logonType">3</field>
<description>SMB Network Logon réussi depuis un poste</description>
<options>no_log</options>
</rule>
```

# TP : CHAP2

**Ex. 2.2 — Configuration Rsyslog**

Pour configurer l'envoi des journaux vers le SIEM, nous allons éditer le fichier /etc/rsyslog.d/50-siem.conf

```
$ActionQueueType LinkedList
$ActionQueueFileName siem_queue
$ActionQueueMaxDiskSpace 1g
$ActionQueueSaveOnShutdown on
$ActionQueueResumeRetryCount -1
$ActionQueueDequeueBatchSize 10000

### Envoi des journaux de niveau warning et supérieur (*.warning)
### Protocole TCP  vers 10.0.0.5 port 6514
*.warning  @@(o)10.0.0.5:6514
```

**Ex. 2.3 — Analyse de la timeline.**

(a) Durée entre le premier scan et la première connexion réussie

| Événement | Timestamp UTC |
|---|---|
| Scan SYN port 22 (pfSense) | 2026-04-18 17:08:15 |
| Authentification SSH réussie (user: backup) | 2026-04-18  18:38:23 |

Durée totale : 1h 30 minutes 08 secondes

(b) EID confirmant l'effacement des journaux

EID 1102  (Security) — srv-erp-01 — 2026-04-18 à 07:37:00

(c) Technique MITRE du mouvement latéral

La technique est T1021.002 (Remote Services: SMB/Windows Admin Shares). Elle est visible à 03:21:15 lors du passage de srv-web-01 vers srv-erp-01

(d) Deux mesures qui auraient interrompu la chaîne dès l'étape 3

| Mesure | Explication |
| --- | --- |
| MFA sur SSH | Même avec le bon mot de passe, une 2e preuve (TOTP, clé physique) aurait bloqué la connexion depuis l'IP externe. |
| Fail2Ban / blocage IP automatique | Après 7 échecs SSH en 45 secondes, l'IP 203.0.113.42 aurait dû être automatiquement bannie avant la connexion réussie. |